

The EU-US Privacy Shield was a legal framework for regulating transatlantic exchanges of personal data for commercial purposes between the European Union and the United States. One of its purposes was to enable US companies to more easily receive personal data from EU entities under EU privacy laws meant to protect European Union citizens. The EU-US Privacy Shield went into effect on 12 July 2016 following its approval by the European Commission. It was put in place to replace the International Safe Harbor Privacy Principles, which were declared invalid by the European Court of Justice in October 2015. The ECJ declared the EU-US Privacy Shield invalid on 16 July 2020, in the case known as Schrems II. In 2022, leaders of the US and EU announced that a new data transfer framework called the Trans-Atlantic Data Privacy Framework had been agreed to in principle, replacing Privacy Shield. However, it is uncertain what changes will be necessary or adequate for this to succeed without facing additional legal challenges.

History

In October 2015 the European Court of Justice declared the previous framework called the International Safe Harbor Privacy Principles invalid in a ruling that later became known as "Schrems I". Soon after this decision, the European Commission and the U.S. Government started talks about a new framework, and on February 2, 2016, they reached a political agreement. The European Commission published the "adequacy decision" draft, declaring principles to be equivalent to the protections offered by EU law.

The Article 29 Data Protection Working Party delivered an opinion on April 13, 2016, stating that the Privacy Shield offers major improvements compared to the Safe Harbor decisions, but that three major points of concern still remain. They relate to deletion of data, collection of massive amounts of data, and clarification of the new Ombudsperson mechanism. The European Data Protection Supervisor issued an opinion on 30 May 2016 in which he stated that "the Privacy Shield, as it stands, is not robust enough to withstand future legal scrutiny

before the [European] Court".

On 8 July 2016 EU member states' representatives (article 31 committee) approved the final version of the EU-U.S. Privacy Shield, paving the way for the adoption of the decision by the commission. The European Commission adopted the framework on 12 July 2016 and it went into effect the same day.

On January 25, 2017, U.S. President Donald Trump signed an executive order entitled "Enhancing Public Safety" which states that U.S. privacy protections will not be extended beyond US citizens or residents:

Agencies shall, to the extent consistent with applicable law, ensure that their privacy policies exclude persons who are not United States citizens or lawful permanent residents from the protections of the Privacy Act regarding personally identifiable information.

This executive order was repealed by President Joe Biden on January 20, 2021.

The European Commission has stated that:

The US Privacy Act has never offered data protection rights to Europeans. The Commission negotiated two additional instruments to ensure that EU citizens' data is duly protected when transferred to the US:

The EU-U.S. Privacy Shield, which does not rely on the protections under the US Privacy Act.

The EU-US Umbrella Agreement, which enters into force on 1 February (2017). To finalize this agreement, the US Congress adopted a new law in 2017, the US Judicial Redress Act, which extends the benefits of the US Privacy Act to Europeans and gives them access to US courts.

The commission said it will "continue to monitor the implementation of both instruments".

Privacy Shield principles

In general, there are seven major principles which the organization has developed. They are

stated in the following paragraphs:

Notice – Individuals must be informed that their data is being collected and how it will be used. The organization must provide information about how individuals can contact the organization with any inquiries or complaints.

Choice – Individuals must have the option to opt out of the collection and forward transfer of the data to third parties.

Accountability for onward transfer – Transfers of data to third parties may only occur to other organizations that follow adequate data protection principles.

Security – Reasonable efforts must be made to prevent loss of collected information.

Data integrity and purpose limitation – Data must be relevant and reliable for the purpose it was collected.

Access – Individuals must be able to access information held about them, and correct or delete it, if it is inaccurate.

Resources, enforcement and liability – There must be effective means of enforcing these rules.

Response

German MEP Jan Philipp Albrecht and Austrian campaigner Max Schrems criticized the new ruling, with the latter predicting that the commission might be taking a "round-trip to Luxembourg" (where the European Court of Justice (CJEU) is located). Many Europeans demanded a mechanism for individual European citizens to lodge complaints over the use of their data, as well as a transparency scheme to assure that European citizens' data does not fall into the hands of US intelligence agencies.

Legal challenge

The Privacy Shield has been challenged legally by privacy groups. Initially, it was not clear

whether the cases would be considered admissible. However, by February 2017 the future of the Privacy Shield was contested. One consultant, Matt Allison, predicted that "The EU's citizen-driven, regulated model will swiftly come into conflict with the market forces of the US and the UK." Allison summarized a new paper in which the European Commission lays out its plans for adequacy decisions and global strategy.

In December 2019, the Court of Justice of the European Union (CJEU) issued a preliminary opinion in the Data Protection Commissioner v Facebook Ireland case (also known as Schrems II). It outlined various scenarios that may result from the conflict in regimes. One lawyer concluded that the opinion "should generate equal measures of relief and alarm for the U.S. government and for companies dependent on data transfers."

A final CJEU decision was published on 16 July 2020 in Schrems II. The EU-US Privacy Shield for data sharing was struck down by the European Court of Justice on the grounds it did not provide adequate protections to EU citizens from government surveillance. The European Data Protection Board (EDPB), an EU organization whose decisions are binding for national privacy supervisory authorities, declared that, "transfers on the basis of this legal framework are illegal". The ruling did not completely stop data transfers between the EU and other foreign countries as the court upheld the use of "standard contractual clauses" (SCCs). But SCCs do not necessarily protect data in countries where the law is fundamentally incompatible with the Charter of Fundamental Rights of the EU and the General Data Protection Regulation (GDPR), like the US. The existing impasse was the subject of ongoing academic proposals and research.

On 25 March 2022 the US and EU announced that a new data transfer agreement had been reached. The new framework, called the Trans-Atlantic Data Privacy Framework, would allow EU citizens to pursue data privacy violations through a new "Data Protection Review Court". On 7 October 2022 President Biden signed an executive order to implement the European Union-U.S. data transfer framework, which adopts new American intelligence gathering

privacy safeguards.

A decision regarding the impact of Brexit on Privacy Shield was expected by 31 December 2020, but may be moot due to the CJEU decision.

The new version is subject to criticism.

Swiss–US Privacy Shield

Switzerland is not an EU member but follows many EU policies through treaty implementations. Accordingly, it has implemented its own version of the Privacy Shield framework through its own Swiss–US Privacy Shield. It is largely similar to the EU–US Privacy Shield framework, but implements its own DPA instead of various EU DPAs. It also has no grace period and several other meaningful differences to the definition of "sensitive data," binding arbitration, and changes to privacy policies. The EU–US and Swiss–US programs were similar enough that they were administered together by the United States.

See also

Binding corporate rules

Electronic Communications Privacy Act

FTC fair information practice (FIPP), US

IT risk

Privacy

Safe harbor (law)

Stored Communications Act

References

External links

Commission Implementing Decision (EU) 2016/1250 of 12 July 2016 on the adequacy of the

protection provided by the EU-US Privacy Shield, now void because of Schrems II

EU-US Privacy Shield fact sheet at the European Union

EU-US Privacy Shield fact sheet at the US Department of Commerce Archived 2016-03-26 at the Wayback Machine